SE-LAB 5
STATIC CODE ANALYSIS

Dairy Collection Program

Course / Subject:	Software Engineering
Student Name:	M Naga Sai Abhiram
USN / Student ID:	PES1UG24AM151
Section / Team:	5C/ Team-06

1. Objective

The objective of this lab was to assess and improve the quality, security, readability, and maintainability of the dairy_collection.py program using Pylint, Bandit, and Flake8. The program was reviewed, identified issues were corrected, and the tools were run again to verify the final source file.

2. Tools Used

- **Pylint:** Evaluates Python code quality, including naming conventions, documentation, and common programming problems.
- **Bandit:** Scans Python source code for common security risks and unsafe patterns.
- **Flake8:** Checks Python style and reports linting and formatting violations.

3. Issues Identified and Remediation

Tool	Issue	Severity / Category	Fix Applied
Bandit	B608: Potential SQL injection from query construction	Medium	Used parameterized SQL queries with placeholders.
Bandit	B324: Weak MD5 hashing algorithm	High	Replaced MD5 with SHA-256.
Bandit	B605: Shell command execution through os.system()	High	Removed shell execution and used a regular print operation for the sample message.
Pylint	C0114: Missing module docstring	Code quality	Added a module-level docstring.
Pylint	C0116: Missing function docstrings	Code quality	Added function docstrings.

Pylint	C0103: Function names did not follow snake_case	Naming	Renamed functions to use snake_case.
Pylint	C0121: Comparison with None using ==	Code quality	Changed the comparison to use is None.
Pylint	C0301: Lines exceeded the configured limit	Formatting	Split long statements and SQL queries across multiple lines.
Pylint	C0209: .format() could be replaced with an f-string	Code quality	Used f-strings where appropriate.
Pylint	W0621: Parameter shadowed an outer-scope name	Code quality	Renamed the database connection parameter to db_conn.
Pylint / Flake8	Unused json import	Code quality	Removed the unused import.
Flake8	E741: Ambiguous variable name l	Naming	Used a descriptive variable name.
Pylint / Flake8	Missing newline at end of file	Formatting	Added the final newline.

4. Before-and-After Results

Metric	Before	After
Pylint score	2.00/10	10.00/10
Bandit findings	3 findings: 1 medium and 2 high	0 findings
Flake8 violations	7 reported violations	0 violations

The initial Pylint score was 2.00/10. After the fixes, the final score was 10.00/10. The initial Bandit scan reported three findings, including two high-severity findings and one medium-severity finding; the final scan reported no issues. Flake8 initially reported seven violations and produced no violation output in the final run.

5. Verification and Testing

The final source file was checked with all three tools. Pylint returned a score of 10.00/10, Bandit reported no identified issues, and Flake8 returned no violations. The program was also executed as a basic functional check after the changes. The generated before-and-after reports are included in the reports directory.

6. Reflection

This lab demonstrated that static analysis tools identify different classes of problems. Pylint highlighted maintainability and code-quality concerns, Bandit identified potentially unsafe security patterns, and Flake8 caught style and formatting violations. Fixing the findings improved documentation, naming consistency, SQL query safety, hashing strength, and formatting. Running the tools again provided measurable evidence that the reported issues had been addressed.

7. Conclusion

The dairy_collection.py program was improved through a combination of security fixes and code-quality cleanup. The final checks achieved a Pylint score of 10.00/10, zero Bandit findings, and zero Flake8 violations.

The source file, findings table, reflection, and generated tool reports together document the work completed for Lab 5.